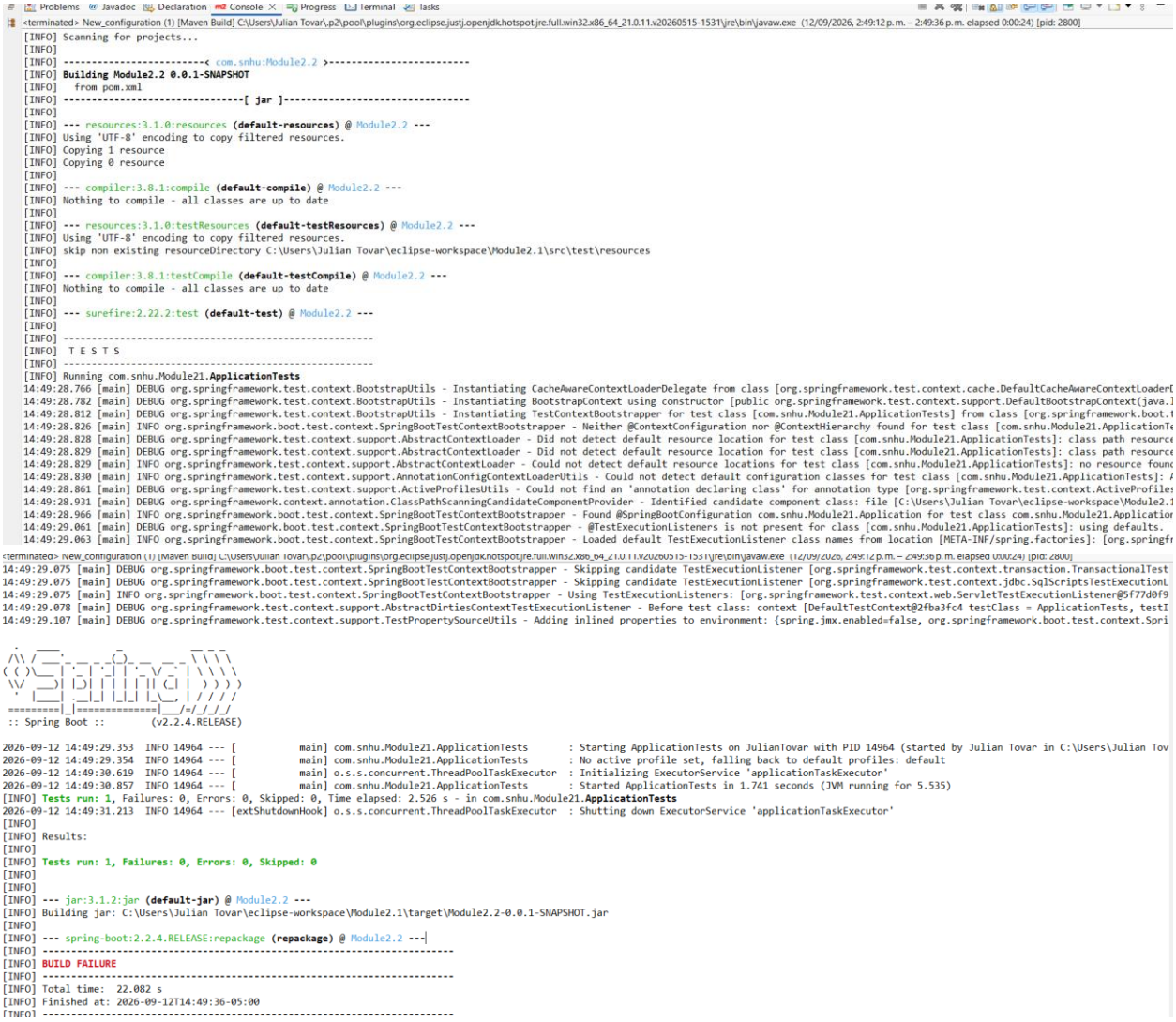
CS 305ES Plantilla para la actividad de codificación del módulo 2

Instrucciones

Sustituya el texto entre corchetes por la información pertinente con sus propias palabras. Si decide incluir imágenes o material de apoyo, asegúrese de agregarlos en los lugares pertinentes del documento.



1. Ejecutar comprobación de dependencias

Se integró OWASP Dependency-Check como herramienta de análisis estático de dependencias para revisar las bibliotecas de terceros utilizadas por la aplicación Spring. El análisis identifica componentes vulnerables mediante la comparación de las dependencias con bases de datos de vulnerabilidades conocidas, incluyendo NVD. En el código base se utiliza Spring Boot 2.2.4.RELEASE y también se incluye

el controlador MongoDB Java Driver 2.4. La revisión muestra que varias dependencias son versiones antiguas y requieren actualización.

2. Documentación de resultados

El informe de Dependency-Check asociado con este código base identifica vulnerabilidades en varias dependencias transitivas y directas. Entre los hallazgos documentados para esta versión del proyecto se encuentran los siguientes:

hibernate-validator-6.0.18.Final.jar: CVE-2020-10693. Vulnerabilidad relacionada con la validación de expresiones que puede permitir una ejecución no deseada bajo determinadas condiciones.

jackson-databind-2.10.2.jar: CVE-2020-25649; CVE-2020-36518; CVE-2021-46877; CVE-2022-42003; CVE-2022-42004. Problemas de deserialización y consumo excesivo de recursos que pueden afectar la disponibilidad o permitir comportamientos no deseados cuando se procesan datos no confiables.

log4j-api-2.12.1.jar: CVE-2020-9488. Vulnerabilidad de seguridad relacionada con la configuración y el manejo de información sensible durante el registro.

logback-core-1.2.3.jar: CVE-2021-42550. Vulnerabilidad que puede afectar la seguridad cuando se utilizan configuraciones específicas de Logback.

mongo-java-driver-2.4.jar: CVE-2021-20328. Problema de validación del nombre del host en determinadas funciones de cifrado del lado del cliente; afecta principalmente escenarios que utilizan CSFLE.

snakeyaml-1.25.jar: CVE-2017-18640; CVE-2022-1471; CVE-2022-25857; CVE-2022-38749; CVE-2022-38750; CVE-2022-38751; CVE-2022-38752; CVE-2022-41854. Incluye problemas de deserialización insegura y varias condiciones de denegación de servicio al procesar YAML no confiable.

spring-boot-2.2.4.RELEASE.jar / spring-boot-starter-web-2.2.4.RELEASE.jar: CVE-2022-27772. Vulnerabilidad asociada con una versión antigua de Spring Boot; la mitigación principal es actualizar a una versión corregida.

spring-core-5.2.3.RELEASE.jar: CVE-2020-5421; CVE-2021-22060; CVE-2021-22096; CVE-2022-22950; CVE-2022-22965; CVE-2022-22968; CVE-2022-22970; CVE-2022-22971; CVE-2023-20861; CVE-2023-20863. Conjunto de vulnerabilidades de Spring Framework relacionadas con diferentes mecanismos de procesamiento, configuración y manejo de solicitudes.

spring-web-5.2.3.RELEASE.jar: CVE-2016-1000027; CVE-2020-5421; CVE-2021-22060; CVE-2021-22096; CVE-2022-22950; CVE-2022-22965; CVE-2022-22968; CVE-2022-22970; CVE-2022-22971; CVE-2023-20861; CVE-2023-20863. Vulnerabilidades de Spring Web que pueden afectar el procesamiento de solicitudes y la seguridad de la aplicación.

spring-webmvc-5.2.3.RELEASE.jar: CVE-2020-5421; CVE-2021-22118; CVE-2021-22060; CVE-2021-22096; CVE-2022-22950; CVE-2022-22971; CVE-2022-22970; CVE-2023-20861; CVE-2023-20863.

Problemas de seguridad en el componente MVC de Spring que requieren mantener el framework actualizado.

tomcat-embed-core-9.0.30.jar / tomcat-embed-websocket-9.0.30.jar: Múltiples CVE. Versiones antiguas de Tomcat presentan vulnerabilidades conocidas, por lo que deben actualizarse junto con la versión compatible de Spring Boot.

3. Análisis de resultados

Los resultados indican que la principal medida de remediación es actualizar las dependencias vulnerables a versiones que contengan los parches de seguridad correspondientes. En particular, SnakeYAML 1.25 debe reemplazarse por una versión corregida porque CVE-2022-1471 puede permitir ejecución remota de código mediante deserialización insegura, mientras que otras vulnerabilidades de SnakeYAML pueden producir denegación de servicio. CVE-2022-25857, por ejemplo, afecta versiones anteriores a 1.31 y se corrige actualizando a 1.31 o superior. Para MongoDB Java Driver también se recomienda abandonar la versión 2.4, que es muy antigua y ya no recibe mantenimiento.

También es recomendable actualizar Spring Boot a una versión soportada y dejar que su sistema de gestión de dependencias seleccione versiones corregidas de Spring Framework, Tomcat y otras bibliotecas transitivas. OWASP señala que Dependency-Check identifica componentes de terceros y los compara con vulnerabilidades públicamente conocidas, por lo que debe incorporarse periódicamente al flujo de desarrollo y, preferiblemente, al proceso de integración continua. Después de actualizar las dependencias, se deben volver a ejecutar las pruebas para confirmar que las vulnerabilidades fueron eliminadas y que la aplicación continúa funcionando correctamente.

Los falsos positivos también representan un problema porque una herramienta puede asociar una dependencia con una vulnerabilidad que realmente no afecta la configuración o el uso concreto de la aplicación. Si el equipo trata todos los resultados como vulnerabilidades reales, puede dedicar tiempo innecesario a correcciones que no reducen el riesgo. Por ello, cada hallazgo debe validarse revisando el CVE, la versión afectada, la ruta de la dependencia y las condiciones necesarias para explotar el problema. Las excepciones o supresiones solo deben utilizarse cuando el equipo haya confirmado y documentado que un hallazgo es un falso positivo o que no es aplicable.

Referencias

- National Institute of Standards and Technology. (s. f.). National Vulnerability Database. https://nvd.nist.gov/

- OWASP Foundation. (s. f.). OWASP Dependency-Check. https://owasp.org/www-project-dependency-check/

- INCIBE-CERT. (2021). CVE-2021-20328. https://www.incibe.es/incibe-cert/alerta-temprana/vulnerabilidades/CVE-2021-20328